



Dossier Technique & Commercial

Plateforme SaaS RH / Pointage

Plateforme web	Concorde Workforce
Application mobile	Concorde Workly
Cycle	Préparation lancement V1
Date	13 mai 2026
Backend	.NET 8 · ASP.NET Core · PostgreSQL 16
Frontend	React 19 · Vite · MUI · TypeScript 5
Mobile	Expo SDK 54 · React Native 0.81
Infra	Serveur dédié OVH KS-5-B (France) · Ubuntu Server 24.04 LTS · Docker Compose · nginx

IA	Qdrant (RAG) · LangChain · multilingual-e5-large
----	--

Document confidentiel — usage interne & partenaires autorisés

Table des matières

1. Synthèse exécutive
2. Architecture fonctionnelle
3. Modules existants
4. Workflows
5. Sécurité mobile renforcée (G1 → G6)
6. Sécurité backend & infrastructure
7. APIs et architecture des services
8. Gestion des rôles et permissions
9. Performances et scalabilité
10. Modules livrés et axes d'enrichissement
11. Stratégie SaaS et segmentation des offres
12. Packs tarifaires et fonctionnalités
13. Stratégie marketing
14. Préparation App Store et Google Play
15. Éléments pour démonstrations commerciales
16. Scénarios opérationnels anticipés
17. Roadmap de développement
18. Plan de durcissement infrastructure de production
19. Services tiers et dépendances
20. Conclusion

1. Synthèse exécutive

1.1 Vision produit

Plateforme SaaS multi-tenant proposant aux PME/ETI une solution intégrée :

- Pointage présentiel et mobile avec géolocalisation
- Gestion RH (employés, contrats, congés, RTT, absences, sanctions)
- Préparation paie (rubriques, états périodiques, exports)
- Coffre-fort numérique pour documents salariés (bulletins, contrats, justificatifs)
- Signature électronique des documents
- Dashboards & reporting analytiques
- Assistant IA contextuel (RAG)

1.2 Maturité actuelle

- **Backend** : 64 contrôleurs API, 131 entités EF Core, multi-tenant master/tenant opérationnel, RAG branché, auto-migration de schéma au démarrage, seed automatique du référentiel pays.
- **Web** : ~30 modules métier complets en MUI, i18n FR/EN, animations, dashboard admin/employé/manager différencié.
- **Application mobile** (22 pages) : authentification par empreinte digitale ou reconnaissance faciale, géolocalisation GPS pour le pointage, notifications instantanées, signature électronique manuscrite, coffre-fort de documents personnels, et protection de la confidentialité (blocage des captures d'écran, détection des appareils piratés, etc.).
- **Tarification verrouillée** : Starter 29,50 € / Standard 59,50 € / Premium 119 € avec facturation forfait + overage Stripe.
- **Plan gating opérationnel** : restrictions backend (`RequirePlanFeatureAttribute`), frontend (`planAllows`) et mobile.
- **Infrastructure** : déployable via `docker compose up`, certificats Let's Encrypt, HSTS + CSP + headers complets.

1.3 Cibles V1 (lancement)

Objectif	Détail	Statut
Multi-tenant billing Stripe	Base + seat items	✓ Fait
Pointage géolocalisé	Fiable cross-fuseau	✓ Fait
Coffre-fort + signature	Flux complet	✓ Fait
Préparation paie	Exports Excel standards	✓ Fait
Hardening sécurité	OWASP top 10 + mobile	✓ Fait
Infra production durcie	Ubuntu 24.04 LTS	☐ En cours

2. Architecture fonctionnelle

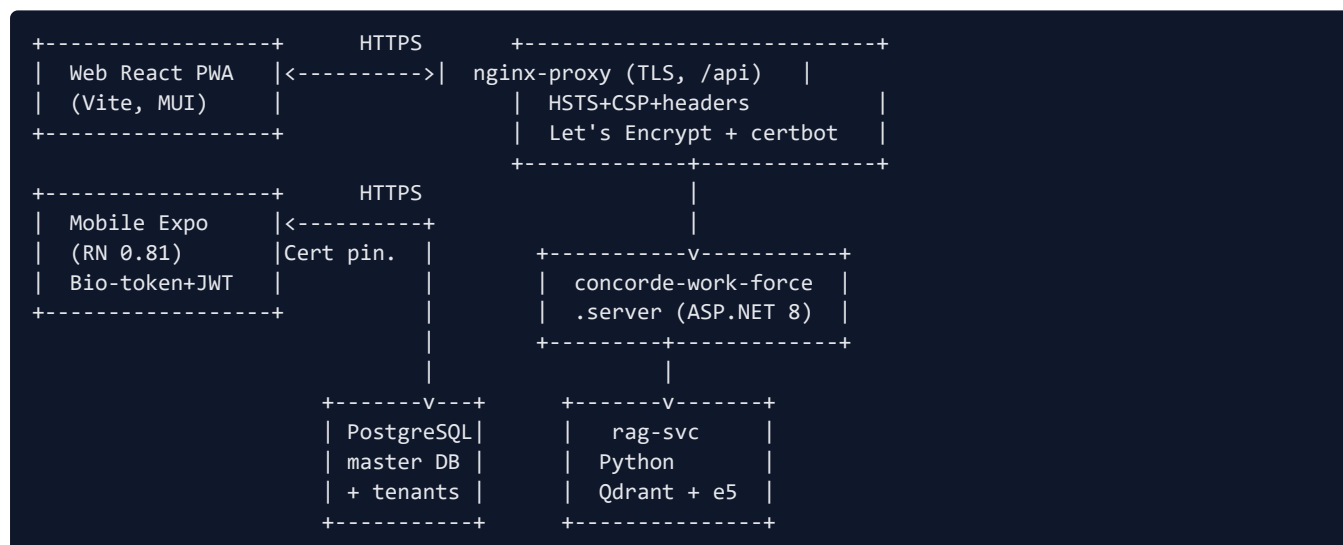
2.1 Architecture de marque

La solution se compose de deux produits commercialement distincts mais techniquement intégrés, sous l'ombre du groupe **Concorde** (éditeur : concorde-tech.fr) :

	Marque	Périmètre
	Concorde Workforce	Plateforme web SaaS d'administration RH et de gestion du temps — destinée aux administrateurs, managers et services paie. Tableau de bord, configuration référentielle, validation des demandes, préparation paie, reporting.
	Concorde Workly	Application mobile compagnon (iOS / Android) destinée aux salariés sur le terrain. Pointage géolocalisé, signature électronique, coffre-fort de documents personnels, demandes de congés, consultation du solde et des plannings.

Les deux produits partagent le même backend (API REST), la même base de données multi-tenant et le même socle d'authentification — la séparation est exclusivement éditoriale et UX.

2.2 Vue d'ensemble technique



2.3 Stack technique

Couche	Technologies principales
Backend API	.NET 8 · ASP.NET Core · EF Core 8 · Dapper 2.1 · AutoMapper 14 · MailKit · BCrypt · Otp.NET (TOTP) · QRCode · Stripe.NET 47 · DinkToPdf · FastReport.OpenSource · DocumentFormat.OpenXml · PdfPig · Microsoft.SemanticKernel 1.30
Web	React 19 · Vite · TypeScript 5 · MUI 5 + x-charts + x-data-grid + x-date-pickers · React Query 5 · React Router · FullCalendar · jsPDF + autotable · ExcelJS · i18next FR/EN · dayjs · Recharts · axios

Couche	Technologies principales
Mobile	Expo SDK 54 · React Native 0.81 · React Navigation 7 · expo-location · expo-camera · expo-document-picker · expo-secure-store · expo-notifications · expo-local-authentication · expo-screen-capture · React Native Paper
Infrastructure	Docker Compose · nginx (proxy + TLS) · PostgreSQL 16 · Qdrant 1.12 · Python sidecar RAG (LangChain + multilingual-e5-large) · certbot
CI/CD	GitHub Actions — pipelines automatisés (build multi-stage, tests, publication images Docker, déploiement) déclenchés à chaque push sur la branche principale

2.4 Topologie Docker Compose

Service	Image	Réseau	Volumes
nginx-proxy	nginx:alpine	app-network 80/443	nginx.conf:ro, uploads RO
concorde-work-force.server	concorde-work-force-server:local	app-network 8080	uploads_data RW
concorde-work-force.client	concorde-work-force-client:latest	app-network 80	—
concorde-work-force.database	postgres:16-alpine	app-network	postgres-data, pg-backup
qdrant	qdrant:1.12.0	app-network 6333/6334	qdrant_data
rag-svc	concorde-work-force-rag-svc:local	app-network 8080	—
certbot	certbot/certbot	—	letsencrypt_data

2.5 Multi-tenant SaaS

Modèle : *Database-per-tenant + master DB.*

```

Master DB (ABRPOINT_master)      Tenant DBs (ABRPOINT_<slug>)
+-----+                       +-----+
| Tenants (slug, host) | -----> | Sites, Employes, |
| TenantEmailIndex    |           | Presences, Vault, etc. |
| Plans, Subscriptions |           | (schema migre a chaud) |
+-----+                       +-----+

```

- **Résolution tenant** : `TenantResolverMiddleware` lit le header `X-Tenant-Slug` ou le sous-domaine.
- **DbContext factory dynamique** : connection string générée via `TenantTemplate` si tenant résolu.
- **Auto-migration** : `BaseDataSchemaMigrator` applique les ALTER TABLE/CREATE INDEX idempotents. Un simple `docker compose up -d` propage les évolutions de schéma.

2.6 Modèle de données (haute densité)

131 entités organisées par familles :

Famille	Entités principales
RH socle	Employe , Empuser , Direction , Fonction , Service , Section , Qualif , Site , Societe , Ville
Pointage	Presence , Pointeuse , Dmpresence
Horaires	Poste , Lposte , Calendsoc , Lcalendsoc , Ferier
Congés/absences	Conge , Demconge , Absence , Sanction , DemandeAutorisation , Autoriser , Allaite ment , Compenser
Paie	Rubrique , NoteDeFrais , Mission
Gestion droits	Roles , RolePermission , RolePointdroit , Module , Modusers
Contrats/docs	Contrat , DocumentVault , LetterTemplate
Tenancy	Tenant , TenantEmailIndex (master DB)
Audit/sécu	AuditLog , RefreshToken
Notifications	PushToken , Notification , NotificationCategoryCatalog
RAG/IA	RagDocument , RagLetterTemplate , RagChatLog , index Qdrant

3. Modules existants

3.1 Authentification & sécurité

- **Login web/mobile** : email + mot de passe BCrypt, JWT 8.0
- **2FA TOTP** : QR code via QRCodeur lors de l'enrôlement, validation à chaque login
- **Tokens** : access token courte durée + RefreshToken long terme chiffré AES
- **Mobile biométrie sans password** (G2) : bio-token dédié (purpose=Biometric, expiry 90j, rotation à chaque usage). Aucun mot de passe stocké sur l'appareil.
- **Quota refresh tokens par utilisateur** (G6) : 5 derniers tokens actifs maximum, les plus anciens révoqués automatiquement.
- **Anti-énumération** : tous les contrôleurs [Authorize] + [ValidateSoccod] , refresh token rotatif.

3.2 Gestion RH

- CRUD complet employé + fiche enrichie (état civil, banque, compétences, sites)
- Hiérarchie : Direction > Service > Section
- Import Excel (rubriques, employés via BulkImportController)

3.3 Pointage & présences

- Pointage manuel (web admin) via état périodique
- Pointage employé (mobile) avec capture GPS, accuracy, horodatage local
- Calculs dédiés : HeureSuppService , HeuresAbsencesService , CalcTotHeuresService , PointageMoisService , PointageOptimizer

- États : périodique, journalier, retards, assiduité, global

3.4 Pointage géolocalisé

- Colonnes `sitlat`, `sitlon`, `sitrad` (rayon m) créées automatiquement par `BaseDataSchemaMigrator`
- Validation Haversine (`GeoZoneValidator.cs`) — source DB prioritaire + fallback config
- Contrôle au pointage : refus 422 `gps_required` / `outside_geofence` si hors rayon
- Tolérance horloge : skew client/serveur bumped à 90 min (couverture Maghreb/Europe DST)

3.5 Congés & autorisations

- Workflow : soumission → manager/admin approve/refuse → titre de congé émis
- RTT : crédit, consommation, solde annuel par employé
- CET (compte épargne temps) : conversion congés non pris
- Demandes d'autorisation de sortie + Autorisations approuvées

3.6 Préparation paie

- Rubriques : CRUD, Excel import, formules
- Pointage du mois : agrégation présences par employé, thread-safe (DbContext scoped)
- Export paie : `DocumentFormat.OpenXml` (Excel) et PDF
- Bulletins via `LetterTemplates` (templates HTML/Razor-like personnalisables)

3.7 Coffre-fort numérique

- Upload via `FormData` multipart (mobile + web)
- Whitelist extensions : pdf, doc/docx, xls/xlsx, csv, png/jpg — bloque exécutables et SVG/HTML scriptables
- Plafond 10 Mo par fichier (override via env `Uploads__MaxSizeMb`)
- Path traversal : noms régénérés en GUID, jamais du nom client
- Audit orphelins : endpoint admin réconciliant DB ↔ filesystem
- Téléchargement direct via nginx (volume `uploads_data` RO) — sans hop backend

3.8 Signature électronique

- Web : `SignaturePad` + base64 → backend via `SaveBase64Image`, fichier `sig_*.png`
- Mobile : capture tactile, upload, statut signé verrouille la suppression. Les captures d'écran sont automatiquement bloquées pendant la session de signature pour préserver la confidentialité du document signé.
- Métadonnées : signataire, date, IP — visibles dans l'audit log

3.9 Notifications & reporting

- Push mobile via Expo Push API, tokens stockés en `PushToken`
- Email : MailKit + SMTP, templates HTML
- In-app : centre de notifications web + mobile, badge unread
- Quiet hours : blocage des notifications hors plage horaire configurée
- Rappels ponctualité : service hébergé balayant périodiquement
- PDF : `DinkToPdf` (HTML→PDF), `FastReport` pour états réguliers

- Excel : DocumentFormat.OpenXml (backend) + ExcelJS (web)

3.10 Inscription, abonnement & cycle de vie tenant

Module ajouté au cours du sprint mai 2026, alignant l'expérience d'achat sur les standards SaaS (Odoo, HubSpot) et la conformité légale française.

- **Inscription publique anti-bot** : page `/signup` protégée par *captcha mathématique* côté serveur (challenge arithmétique généré, validation à usage unique via `IMemoryCache` avec TTL 5 min) — pas de dépendance externe Google reCAPTCHA, RGPD-friendly
- **Sélection de plan amont** : Starter / Standard / Premium choisis avant création du tenant ; le plan détermine immédiatement les modules visibles (cf. §8 gating)
- **Essai gratuit 30 jours** sur tous les plans (sans CB requise) — politique unifiée mai 2026, anciennement réservée à Standard. Le tenant en essai accède aux modules de *son plan sélectionné* (pas Premium-pour-tous) pour cohérence avec la promesse commerciale et éviter l'effet falaise au paiement
- **Paiement Stripe Checkout** : abonnement récurrent mensuel, prix forfaitaire + overage par salarié au-delà du seuil inclus ; webhook signé `customer.subscription.{created|updated|deleted}` synchronise l'état tenant
- **Résiliation libre** (`BillingController.cs`) : deux modes — *immédiate* (Stripe `CancelAsync`, accès coupé) ou *fin de période* (`cancel_at_period_end`, l'utilisateur conserve l'accès jusqu'à la date payée). Réservée Admin/Manager via vérification base de données du rôle (`Utiadm` / `Utirole`)
- **Réactivation post-résiliation** conforme au droit français du contrat : tenant en statut `Cancelled` conservé **90 jours en rétention** ; pendant cette fenêtre, l'utilisateur peut se ré-inscrire avec la *même adresse e-mail* et récupérer ses données (l'API `/signup` renvoie le code `cancelled_account_reactivatable` et redirige vers `/login`, l'endpoint `/billing/resume-checkout` accepte les `Cancelled`). Au-delà de 90 jours : suppression effective (RGPD *droit à l'effacement*)
- **Reprise d'abonnement** : avant la date de coupure, l'admin peut annuler la résiliation en un clic (Stripe `cancel_at_period_end = false`)
- **Multi-tenant strict** : `TenantResolverMiddleware` bypass explicitement `/api/billing/*` pour les tenants `Suspended/Cancelled/Failed` afin de permettre le flux de réactivation sans contourner les autres protections

3.11 Catalogue de plans & gating commercial (PlanCatalog)

Source de vérité unique [`PlanCatalog.cs`] côté serveur, exposée au frontend via `/api/Utilisateurs/me` (clé `planFeatures`) et au mobile via `/MobileAuth/me`.

- **19 drapeaux fonctionnels** par plan (booléens) : application mobile, géolocalisation, coffre-fort numérique, signature électronique, multi-site, multi-société, tableaux de bord avancés, IA RAG, audit logs avancés, branding personnalisé, device trust, anti-screenshot, certificate pinning, missions, jours de compensation, congé général, autorisation générale, gestion congés, gestion autorisations
- **Limites quantitatives** : effectifs inclus, tarif overage par employé, nombre max de sociétés/sites — calculées via `PlanCatalog.GetLimits`
- **Plan Starter (29,50 €/mois, 10 salariés inclus)** : positionnement « pointage simple, sans workflow RH » — exclut explicitement le coffre-fort, la signature électronique, les missions, les jours de compensation, le congé général, l'autorisation générale, la gestion des congés (demande + titre), la gestion des autorisations (saisie + demande), l'assistant IA. **Conserve** l'état périodique du pointage
- **Plan Standard (59,50 €/mois, 25 salariés inclus)** : ajoute mobile, géolocalisation, coffre-fort, signature, multi-site, dashboards avancés, missions, jours de compensation, congé/sortie générale, workflow

congé/autorisation complet — exclut IA RAG, audit logs avancés, branding, sécurité durcie

- **Plan Premium (119 €/mois, 50 salariés inclus, illimité sociétés/sites)** : tout activé, incluant l'IA et le durcissement de sécurité mobile
- **Application backend** : attribut `[RequirePlanFeature(nameof(PlanFeatures.X))]` sur les contrôleurs/actions → retourne HTTP 402 avec code stable `plan_feature_locked` que le front transforme en pop-up « Upgradez votre plan »
- **Application frontend** : hook `useAuth().planAllows(feature)` filtre la navigation latérale → les modules verrouillés disparaissent du menu (pas seulement grisés)

4. Workflows

4.1 Workflow employé (mobile — golden path)

```

Login email/pwd --> (2FA TOTP si active) --> JWT + refresh
|
v (option : enrolement biometrique -> bio-token serveur)
HomeScreen --> [Bouton POINTER]
|
| capture GPS (expo-location, 5s timeout)
| POST /Presences/mark-presence/{soc}/{emp}
|
v
Backend valide :
+- caller owns/manages employee OK
+- skew clock <= 90 min OK
+- si geofence : GPS requis + dans rayon OK
+- dans periode d'emploi OK
v
INSERT/UPDATE presence + log GPS
|
+---> Vault : upload doc / consulter / signer
+---> Demandes conge / autorisation
+---> Auto-lock apres 10 min inactivite
+---> Notifications push (Expo)

```

4.2 Workflow administrateur (web)

Le workflow admin couvre : Données de Base (Filiales, Sites, Villes), Gestion Employés (création, contrats, sanctions), Pointage (état périodique, optimiseur, imports CSV), Congés (workflow approbation), Préparation Paie (rubriques, pointage mois, états PDF), Vault (upload bulk + audit orphelins), et Paramètres (rôles & permissions, plan/billing Stripe, notifications opt-in).

4.3 Workflow manager

Sous-ensemble de l'admin scopé à son service/section : approbation congés/autorisations de son équipe, vue dashboard via `ManagerDashboardController`.

4.4 Workflow signup tenant (onboarding technique)

```
Landing /signup --> [SignupController] (rate-limited 3/h/IP)
|
v
1. Validation email unicite (master DB -> TenantEmailIndex)
2. Creation Tenant (slug = sous-domaine, host)
3. Creation tenant DB (BaseDataSchemaMigrator clone schema)
4. Provisioning admin initial
5. Stripe customer si plan payant ; trial period sinon
6. Email welcome + login -> tenant scope actif
```

5. Sécurité mobile renforcée (G1 → G6)

Six durcissements appliqués en plus du socle JWT/HTTPS :

ID	Risque	Mitigation	Plan
G1	MITM via CA compromise	Certificate Pinning (Android <code>network_security_config.xml</code> + iOS <code>NSPinnedDomains</code>)	Tous (build-time)
G2	Vol credentials sur device	Bio-token sans password — endpoints <code>/MobileAuth/biometric-*</code>	Standard+
G3	Reverse-engineering émulateur / root	Device trust assessment (<code>deviceSecurity.ts</code>), détection Genymotion / BlueStacks / Nox, OS obsolètes	Premium
G4	Exfiltration via screenshot	<code>expo-screen-capture</code> + hook <code>useSecureScreen</code> sur Vault, Signature, Profile	Premium
G5	Session orpheline device perdu	Auto-lock 10 min foreground / 5 min arrière-plan, overlay LockScreen + Face ID	Standard+
G6	Sessions persistantes infinies	Quota 5 RT actifs / user, révocation automatique des plus anciens	Tous

Note sur G1 (cert pinning) : la configuration est native au binaire mobile et n'est pas désactivable au runtime. Un client Standard bénéficie *de facto* du cert pinning. La valeur différenciante Premium reste G3/G4 (device trust + anti-screenshot).

6. Sécurité backend & infrastructure

6.1 Surface protégée (OWASP Top 10)

Vecteur	Mitigation
A01 — Broken Access Control	<code>[Authorize]</code> + <code>[ValidateSoccod]</code> + permissions par module + caller-owns checks
A02 — Cryptographic Failures	BCrypt (passwords), refresh tokens chiffrés AES, TLS 1.2/1.3 only, HSTS preload 1 an + <code>includeSubDomains</code>

Vecteur	Mitigation
A03 — Injection	EF Core paramétré ; pas de SQL concaténé utilisateur
A04 — Insecure Design	Garde-fous métier explicites (skew clock, hire/termination dates, GPS requis si geofence)
A05 — Security Misconfig	Header serveur masqué (<code>AddServerHeader = false</code>), <code>server_tokens off</code> côté nginx, erreurs masquées en prod
A07 — Identification & Auth Failures	2FA TOTP, refresh rotatif + quota 5/user (G6), rate-limit <code>clock-in</code> (6/min/IP), <code>auth-signup</code> (3/h/IP), <code>auth-login</code>
A08 — Software & Data Integrity	Whitelist d'extensions uploads (anti-RCE), nginx <code>deny</code> sur <code>.php/.exe/.sh</code> dans <code>/api/uploads/</code>
A09 — Logging & Monitoring	Logging structuré (<code>ILogger<></code>), table <code>AuditLog</code> pour actions critiques
A10 — SSRF	Sidecar RAG isolé sur réseau interne uniquement
Path traversal	Nommage UUID, répertoire parent constant
Mass assignment	DTOs explicites, récupération entité serveur avant patch
CSRF	Stateless JWT (Bearer header) → non applicable

6.2 Headers HTTP (nginx-proxy)

```

Strict-Transport-Security: max-age=31536000; includeSubDomains; preload
X-Content-Type-Options: nosniff
X-Frame-Options: SAMEORIGIN
Referrer-Policy: strict-origin-when-cross-origin
Permissions-Policy: geolocation=(self), camera=(self), microphone=()
Cross-Origin-Opener-Policy: same-origin
Cross-Origin-Resource-Policy: same-origin
Content-Security-Policy: default-src 'self'; img-src 'self' data: https;;
  style-src 'self' 'unsafe-inline'; script-src 'self' 'unsafe-inline';
  font-src 'self' data;; frame-src 'self' blob;; frame-ancestors 'self';
  base-uri 'self'; form-action 'self';

```

6.3 Healthchecks

- `GET /healthz` → liveness (le process répond)
- `GET /readyz` → readiness (DB ping `SELECT 1`) — utilisable par orchestrateur ou monitoring externe

7. APIs et architecture des services

7.1 Conventions REST

- Préfixe `/api`
- Routes : `/api/<Resource>` + `/{{soccod}}/...` quand soccod fait partie du chemin
- **Statuts métier custom** : 402 (quota plan dépassé), 422 (règle métier violée), 403 (permission refusée)
- **Headers requis** : `Authorization: Bearer <jwt>`, `X-Tenant-Slug`

7.2 Services horizontaux

Service	Rôle
EncryptionService	Chiffrement symétrique des refresh tokens et données sensibles
EmailService	Envoi MailKit avec templates HTML
ExpoPushService	Push mobile via Expo Push API (batchs, retries, nettoyage des tokens expirés)
GeoZoneValidator	Validation Haversine geofence (DB + configuration)
PunctualityReminderHostedService	Background service de rappels de ponctualité
QuietHoursResolver	Filtre des notifications hors plage horaire
AiService + Rag/	Indexation, recherche sémantique et génération IA
BaseDataSchemaMigrator	Provisionnement du schéma tenant à la volée

8. Gestion des rôles et permissions

8.1 Modèle

- **Role** : Administrator , Manager , ResponsableRH , Employe , Comptable
- **RolePermission** : matrice rôle × module avec drapeaux RpConsult , RpAdd , RpModify , RpDelete
- **Modules** : ~30 modules métier
- Utiadm = '1' : super-admin tenant, bypass total

8.2 Plan gating (verrouillage par pack commercial)

Couche	Mécanisme	Comportement en cas de refus
Backend	Attribut [RequirePlanFeature(...)] sur contrôleur / action, résolu par réflexion sur PlanFeatures	HTTP 402 avec payload { code: "plan_feature_locked", feature, currentPlan, message }
Frontend web	Hook useAuth().planAllows('featureKey') alimenté par /me	Éléments de navigation masqués ; intercepteur axios redirige les 402 vers /upgrade
Mobile	AuthContext.user.planFeatures rempli au login et à /MobileAuth/me	Hooks useDeviceTrust / useSecureScreen désactivés hors Premium

Endpoints gâtés :

Endpoint	Feature requise	Effet pour Starter
POST /api/MobileAuth/login	MobileApp	App mobile inaccessible
POST /api/Presences/mark-presence (avec GPS)	Geolocation	Refus 402
Toutes routes /api/Vault/*	DigitalVault	Coffre masqué

Endpoint	Feature requise	Effet pour Starter
POST /api/Vault/sign/{id}	ElectronicSignature	Refus 402
Toutes routes /api/Rag/*	RagAi	Assistant IA inaccessible

Pendant l'essai gratuit (statut `Trialing`), `RequirePlanFeatureAttribute` accorde toutes les features pour permettre l'évaluation complète. La facturation démarre à la conversion.

9. Performances et scalabilité

9.1 Techniques en place

- EF Core : `AsNoTracking()` sur tous les reads, queries projetées, pas de N+1 connus
- Pagination systématique
- Cache permissions (`IMemoryCache` ttl ~1 minute)
- Uploads statiques servis directement par nginx — bypass backend, CDN-friendly

9.2 Roadmap d'optimisation technique

Plan d'évolution continue pour anticiper la montée en charge et accompagner la croissance commerciale au-delà du périmètre actuel.

#	Axe d'évolution	Bénéfice attendu
1	Mise en pool des connexions base (<code>IDbContextFactory<></code>)	Optimisation de la latence pour les déploiements à fort volume (>200 tenants)
2	Génération PDF asynchrone (queue Hangfire)	Meilleure réactivité sur les exports massifs (paie, rapports annuels)
3	Cache distribué Redis (<code>IDistributedCache</code>)	Préparation au déploiement multi-instance pour la haute disponibilité
4	Tests end-to-end automatisés (Playwright / Detox)	Renforcement de la couverture qualité au-delà des tests unitaires actuels
5	Indexation RAG temps réel sur dépôt de document	Disponibilité immédiate des nouveaux documents dans l'assistant IA
6	Read replicas régionales PostgreSQL	Réduction de la latence pour les tenants hors Europe
7	Observabilité APM (OpenTelemetry + Grafana)	Diagnostic proactif et tableaux de bord d'exploitation enrichis

10. Modules livrés et axes d'enrichissement

10.1 Modules finalisés

Module	Statut
Auth login + 2FA	✓ Complet
Bio-token mobile (sans password)	✓ Backend + mobile
Multi-tenant master/tenant + auto-migration	✓ Complet
Pointage manuel + mobile	✓ Complet
Géolocalisation pointage	✓ Schéma + service + UI
Calculs présence / retard / heures sup.	✓ Tests unitaires
Congés (demandes, titres, RTT, CET)	✓ Workflow complet
Autorisations de sortie	✓ Complet
Coffre-fort (web + mobile)	✓ Audit orphelins admin
Signature électronique	✓ Web + mobile
Notifications push + email + in-app	✓ Quiet hours + catalogue
Dashboard admin / manager / employé	✓ Animations count-up
Reporting PDF / Excel	✓ Suite complète
Préparation paie (rubriques + pointage mois)	✓ Exports complets
Stripe billing	✓ Webhooks + plan limits 402
RAG / chatbot IA	✓ Indexation + chat contextuel
Sécurité mobile G1-G6	✓ 6 durcissements actifs
Headers sécurité + healthchecks	✓ HSTS + CSP + COOP/CORP
Auto-migration de schéma	✓ <code>BaseDataSchemaMigrator</code>

10.2 Axes d'enrichissement planifiés

Liste des prochaines itérations produit, dans la continuité du périmètre V1 livré.

Module	Évolution planifiée
Geofence	Enrichissement de la documentation utilisateur (guide pas-à-pas de configuration des sites)
RAG — fraîcheur index	Mise en place de la réindexation incrémentale automatique lors d'un dépôt sur le coffre-fort
Onboarding tenant	Enrichissement du guide de premier login (<code>OnboardingGuide.tsx</code>) avec parcours interactif
Sauvegardes	Activation du planificateur cron sur le serveur de production (scripts <code>backup.sh</code> / <code>restore.sh</code> déjà livrés)

11. Stratégie SaaS et segmentation des offres

11.1 Segmentation cible

Segment	Profil	Plan	Volume
TPE / petites équipes	1-10 salariés, RH de base	Starter	10 inclus
PME en croissance	10-50 salariés, mobile + congés + paie	Standard	25 inclus
ETI / Multi-filiales	25-100+ salariés, IA + sécurité renforcée	Premium	50 inclus
Groupes / Comptes clés	> 100 salariés, API / SSO	Premium + add-ons	overage

11.2 Marché géographique prioritaire

1. **France** (cœur V1) : 4M+ PME, pression réglementaire (loi El Khomri, RGPD)
2. **Belgique** : extension naturelle, législation RH proche, marché francophone
3. **Maghreb / Afrique francophone** : Tunisie, Maroc, Algérie, Sénégal, Côte d'Ivoire
4. **DOM-TOM** : couverture cross-fuseau native (skew 90 min)

11.3 Modèle d'abonnement

- **Facturation** : forfait mensuel fixe + overage par salarié supplémentaire
- **Modèle Stripe** : subscription à 2 items — `base` (qty=1) + `seat` (qty=overage)
- **Engagement** : sans engagement de durée. L'utilisateur résilie à tout moment, selon deux modalités au choix : *résiliation immédiate* (effet instantané, sans remboursement de la fraction non utilisée du mois en cours) ou *résiliation à l'échéance* (l'utilisateur conserve l'accès jusqu'au terme de la période déjà payée, aucune facturation ultérieure). Aucun remboursement prorata temporis n'est appliqué — modalité conforme aux usages des abonnements SaaS mensuels reconductibles.
- **Essai** : 30 jours gratuits sur tous les packs payants, sans carte bancaire
- **Job synchronisation seats** : `EmployeeBillingSyncService` (BackgroundService, 24 h)

12. Packs tarifaires et fonctionnalités

12.1 Pack Starter — 29,50 € / mois

Cible : TPE / petites équipes

Tarif : 29,50 € HT/mois — jusqu'à 10 salariés inclus — au-delà : +4,90 €/salarié supplémentaire

Essai : 30 jours gratuits, sans carte bancaire

Inclus : Gestion RH de base, pointage web manuel, calendrier d'absences, tableau de bord simple, exports PDF/Excel basique, 1 administrateur, support J+2.

Désactivé (402 si appel direct) : X App mobile X Pointage géolocalisé X Coffre numérique X Signature électronique X Multi-sites / sociétés X Assistant IA

12.2 Pack Standard — 59,50 € / mois **POPULAIRE**

Cible : PME en croissance

Tarif : 59,50 € HT/mois — jusqu'à 25 salariés inclus — au-delà : +6,90 €/salarié supplémentaire

Essai : 30 jours gratuits, sans carte bancaire

Tout le Starter, plus :

- ✓ Application mobile (iOS + Android, biométrie, push)
- ✓ Pointage géolocalisé (geofence par site)
- ✓ Gestion congés complète (RTT, CET, sanctions)
- ✓ Coffre-fort numérique
- ✓ Signature électronique
- ✓ Notifications push + email + in-app
- ✓ Reporting avancé (PDF / Excel complets)
- ✓ Préparation paie (export Sage Excel)
- ✓ Multi-sites (MaxSites=3)
- ✓ Support prioritaire (SLA 24 h)

Désactivé : ✗ Multi-sociétés ✗ Assistant IA ✗ Device trust / Screenshot blocking runtime

12.3 Pack Premium — 119,00 € / mois

Cible : ETI / Multi-filiales

Tarif : 119 € HT/mois — jusqu'à 50 salariés inclus — au-delà : +9,90 €/salarié supplémentaire

Essai : 30 jours gratuits, sans carte bancaire

Tout le Standard, plus :

- ✓ Multi-sociétés illimité + multi-sites illimité
- ✓ Tableaux de bord avancés (KPI temps réel)
- ✓ Assistant IA contextuel (RAG Qdrant + sidecar Python)
- ✓ Audit logs avancés (export RGPD)
- ✓ Sécurité mobile renforcée (`useDeviceTrust` + `useSecureScreen` actifs)
- ✓ Cert pinning (contractuellement Premium)
- ✓ Conformité RGPD avancée
- ✓ Onboarding accompagné (kick-off call, formation admin + manager)

Roadmap V1.1 (add-on) : API publique · SSO entreprise (SAML/OIDC) · Connecteurs paie directs (Sage, Cegid)

12.4 Add-ons (sur devis)

- Pen-test annuel personnalisé
- Hébergement région dédiée (FR / BE / MA)
- Marque blanche complète (custom CSS + domaine personnalisé)
- API publique pour intégrateurs partenaires
- Formation présentielle administrateurs / managers

13. Stratégie marketing

13.1 France

Positionnement : alternative française à Factorial / Skello / Combo, focus pointage géolocalisé + RGPD natif.

Canaux : SEO (blog RH réglementaire), LinkedIn ads PME 10-200, partenariats experts-comptables, salons (Solutions RH Paris, Workspace Expo), SEA Google, référencement Capterra / GetApp / Appvizer.

13.2 Belgique

Positionnement : extension France, conformité RGPD identique, marché francophone Wallonie + Bruxelles.

Canaux : partenariats secrétariats sociaux (Acerta, SD Worx, Partena), LinkedIn Bruxelles / Wallonie, connecteurs paie locaux (Acerta en roadmap).

13.3 Afrique francophone (Maghreb + UEMOA)

Positionnement : modernisation pointage / paie pour PME / ETI, argument mobile-first (pénétration smartphone élevée), bio-token sans connexion permanente.

Pricing adapté : grille spécifique en MAD / TND / DZD / XOF (-30 à -50 % vs grille EUR).

13.4 Calendrier indicatif

Trimestre	France	Belgique	Afrique francophone
T1 V1	Lancement public, SEA, salons	—	—
T2 V1	Capterra / GetApp, contenus blog	Lancement Wallonie	Pilote 2-3 partenaires
T3 V1	Salons régionaux	Salons Bruxelles	Lancement Maroc + Tunisie
T4 V1	Account-based marketing ETI	Roadmap Acerta	Extension UEMOA

14. Préparation App Store et Google Play

14.1 Prérequis comptes

- ☐ Compte Apple Developer (99 \$/an) au nom de l'entité Concorde
- ☐ Compte Google Play Developer (25 \$ one-shot)
- ☐ Certificats iOS (distribution + push) via Apple Developer Portal
- ☐ Keystore Android signé, backupé hors repo

14.2 Prérequis techniques (en place)

- ✓ Build EAS Expo configuré (`eas.json` prod / preview)
- ✓ Bundle ID iOS et `applicationId` Android distincts
- ✓ Icône adaptive Android paddée
- ✓ `network_security_config.xml` Android pour cert pinning prod

- ✓ Info.plist iOS avec NSPinnedDomains + permissions
- ✓ Versioning automatique via Expo

14.3 Risques de rejet anticipés

Risque	Mitigation
Apple : « app trop similaire à un site web »	Justifier les fonctions natives : GPS, biométrie, push, capture signature
Apple : usage géolocalisation arrière-plan	Pas d'arrière-plan — uniquement on-demand au pointage. À documenter en review notes.
Google : Data Safety incohérent	Audit checklist data collected vs déclaré
Cert pinning trop strict	Pinning conditionnel build prod uniquement ; dev pointe vers staging

15. Éléments pour démonstrations commerciales

15.1 Scénarios de démo (15-20 min)

Démo 1 — Pointage simplifié (5 min) Connexion mobile employé → pointage entrée avec GPS → vue temps réel admin → tentative hors zone → refus 422.

Démo 2 — Cycle congé complet (5 min) Demande mobile → notification manager → approbation → notification employé → solde mis à jour + titre PDF.

Démo 3 — Coffre-fort & signature (5 min) Upload bulletin → notification employé → signature tactile → statut signé verrouillé → audit log.

Démo 4 — Préparation paie (5 min) Pointage du mois agrégé → export Excel → état périodique PDF → KPIs dashboard.

15.2 Arguments différenciants

1. **Sécurité mobile bancaire** : cert pinning + screenshot blocking + auto-lock + bio-token sans password (rare sur le marché RH)
2. **IA contextuelle** : assistant RAG sur vos documents — pas sur des données génériques
3. **Multi-tenant strict** : 1 base SQL par client, isolation forte, hébergement région possible
4. **Mobile-first** : 22 écrans natifs, pas une web-view dégradée
5. **Geofence natif** : inclus dès Standard, pas un add-on
6. **Conformité RGPD** : retention dates, soft delete, export, registre, audit log
7. **Internationalisation** : FR/EN + multi-devise + skew horloge 90 min DST-safe

16. Scénarios opérationnels anticipés

Cette section recense les scénarios d'exploitation pour lesquels des mesures préventives ont été mises en place, conformément aux bonnes pratiques SaaS de continuité de service.

Scénario opérationnel anticipé	Mesures préventives en place
Continuité de service base de données	Sauvegardes horaires chiffrées hors site (S3 EU), procédure de restauration documentée et testée mensuellement, plan de bascule disponible pour les déploiements Premium
Notifications push à grande échelle	Monitoring du volume Expo Push avec seuils d'alerte, capacité de bascule sur FCM en direct si nécessaire
Croissance des volumes de stockage	Alerte à 80 % d'utilisation, politique de rotation et d'archivage des fichiers anciens
Synchronisation événements Stripe	Tâche de réconciliation quotidienne entre Stripe et la base interne, signature des webhooks vérifiée
Maîtrise des coûts IA	Quotas par tenant configurables, modèles secondaires moins coûteux disponibles en fallback automatique
Veille de sécurité dépendances	<code>dotnet list package --vulnerable</code> intégré au pipeline CI, Dependabot actif sur les dépôts (notifications immédiates sur CVE publiées)
Continuité du pinning de certificats mobile	Pinning des certificats intermédiaires Let's Encrypt R10/R11 (et non du certificat feuille), procédure documentée pour rotation anticipée avant expiration

17. Roadmap de développement

17.1 Phase 1 — Hardening V1 (T+0 à T+3 semaines)

- ✓ Plan gating end-to-end (backend + frontend + mobile)
- ✓ Tarification commerciale verrouillée + Stripe base+seat
- ✓ Période d'essai 30 j sans CB
- ✓ Job synchronisation seats Stripe (BackgroundService quotidien)
- ✓ CSP `frame-src blob:` pour aperçus PDF
- ☐ Backups uploads + SQL automatisés (cron production)
- ☐ Monitoring Prometheus + alerting
- ☐ Pen-test externe et remédiation
- ☐ Documentation utilisateur (admin & employé)
- ☐ Build EAS production iOS + Android signés
- ☐ Serveur Ubuntu 24.04 LTS durci — commande passée, mise en place \$18

17.2 Phase 2 — Lancement V1 (T+3 à T+5 semaines)

Pricing public, Stripe live, onboarding guidé enrichi, centre d'aide / FAQ, status page publique, métriques business (MRR, churn), soumission stores.

17.3 Phase 3 — V1.1 (T+6 à T+10 semaines)

Redis + scale horizontal, queue rapports asynchrone (Hangfire), réindexation RAG automatique, connecteurs paie (Sage, Cegid), API publique, SSO (SAML/OIDC), moteur branding, mode offline mobile.

17.4 Phase 4 — V2 (T+3 mois et plus)

Workflow personnalisable (BPMN-light), multi-langue étendu (AR, ES), hébergement régional (FR / BE / MA / SN), failover PostgreSQL (réplication streaming) + load balancer multi-AZ (Premium SLA 99,9 %).

18. Plan de durcissement infrastructure de production

18.1 Spécifications du serveur commandé

Caractéristique	Valeur retenue	Justification
Hébergeur	OVHcloud — datacenter France	Souveraineté des données + conformité RGPD (CNIL), garantie de traitement sur le territoire de l'Union européenne
Modèle de serveur	Serveur dédié OVH KS-5-B	Ressources physiques exclusivement allouées à Concorde Workforce (pas de mutualisation avec d'autres clients)
OS	Ubuntu Server 24.04 LTS	Support de sécurité jusqu'en avril 2029, .NET 8 supporté
Stockage	SSD NVMe	Performance PostgreSQL (WAL + index) + génération des rapports synchrones
RAM	64 Go	shared_buffers PostgreSQL typiquement 25 % ; reste partagé entre Kestrel, nginx, Qdrant, sidecar RAG
Architecture	Évolutive	Compatible déploiement multi-instance + cache Redis pour la croissance

18.2 Architecture cible (3 environnements)

```

+-----+ +-----+ +-----+
| PRODUCTION | | STAGING | | TESTS / CI |
| *.concorde-... | | staging.* | | ephemere docker |
| Stripe live | | Stripe test | | data reinit. |
| Donnees reelles | | Dump anonymise | | pas de backup |
| Backups quotid. | | Backups hebdo | | |
+-----+ +-----+ +-----+

```

18.3 Étapes de sécurisation

Phase 0 — Provisioning initial (J0 à J+1)

1. Installation Ubuntu Server 24.04 LTS (partition `/var/lib/docker` séparée)
2. Utilisateur `concorde-ops` non-privilégié avec `sudo`, désactivation root
3. SSH par clé uniquement (`PasswordAuthentication no`, `PermitRootLogin no`)
4. `ufw` : INPUT default deny ; autoriser 22/tcp (SSH), 80/tcp, 443/tcp
5. `fail2ban` sur sshd (jail 24 h après 3 tentatives)
6. `unattended-upgrades` pour mises à jour sécurité automatiques

7. `auditd` activé (logs syscalls sensibles)

Phase 1 — Stack applicative

Docker Engine + Docker Compose v2 (repo officiel), volumes dédiés NVMe, premier `docker compose up -d` avec healthchecks.

Phase 2 — DNS et TLS

Pointage `A/AAAA` `concorde-work-force.com` + wildcard `*.concorde-work-force.com`, certbot DNS-01 challenge, HSTS preload après stabilisation 1 semaine.

Phase 3 — Monitoring

UptimeRobot sur `/api/healthz` (1 min) + `/readyz` (5 min), logs centralisés, alertes (5xx > 1 %, p95 > 2 s, disque > 80 %, certs < 14 j).

18.4 Politique de sauvegarde

Quoi	Quand	Où	Rétention	Test restore
PostgreSQL (master + tenants)	Quotidien 03:00 UTC (<code>pg_dump</code> chiffré)	S3 EU chiffré	30 j rolling + 12 fins de mois	Mensuel
Volume <code>uploads_data</code>	Quotidien 03:30 UTC	Idem	30 j rolling	Mensuel
Config nginx / appsettings	Git + snapshot hebdo	Git + S3	Indéfini	Sur modif.
Volume Qdrant (RAG)	Hebdomadaire	Idem	4 semaines	Trimestriel

18.5 Plan de continuité de service (V1)

- **RPO cible** : 24 h (sauvegarde quotidienne)
- **RTO cible** : 4 h (restauration + redéploiement)
- **Modèle de résilience V1** : architecture mono-instance avec sauvegardes testées et procédure de restauration documentée — dimensionnée pour un engagement de service de niveau Standard (99 %). La haute disponibilité avec bascule automatique (réplication PostgreSQL streaming + load balancer multi-AZ) est planifiée dans le palier Premium SLA 99,9 % (cf. §9.2 roadmap).

19. Services tiers et dépendances

19.1 Services externes payants

Service	Usage	Plan V1
Stripe	Billing abonnements + webhooks	Standard, frais 1,4 % + 0,25 € EU
OpenRouter (Gemini 2.0 Flash)	LLM RAG	Pay-as-you-go ; switch Claude possible
Expo Push API	Notifications mobile	Gratuit (~6000 push/min)

Service	Usage	Plan V1
Let's Encrypt	TLS	Gratuit
SMTP (TBD)	Emails transactionnels	SendGrid / Mailgun / SES
Apple Developer	Distribution iOS	99 \$/an
Google Play Developer	Distribution Android	25 \$ one-shot

20. Conclusion

La plateforme est dans un état de **maturité fonctionnelle élevée** : modules métier complets, multi-tenant opérationnel avec auto-migration de schéma, calculs paie couverts par tests, sécurité socle forte et durcissements mobiles bancaires (cert pinning, bio-token, device trust, screenshot blocking, auto-lock, RT quota) — les deux derniers gatés Premium au runtime.

La **tarification commerciale est verrouillée** (Starter 29,50 € / Standard 59,50 € / Premium 119 €) avec un modèle forfait + overage par salarié, période d'essai 30 jours sans CB, et facturation Stripe à 2 items avec synchronisation automatique des seats.

Le **plan gating est appliqué de bout en bout** : backend (`RequirePlanFeatureAttribute`), frontend (`planAllows`), mobile (hooks conditionnés au plan). Un tenant Starter ne peut pas accéder à l'app mobile, au coffre, à la signature, au reporting avancé, ni à l'IA — y compris par appel direct à l'API.

Les **trois axes prioritaires** de la phase de mise en production sont :

1. **Continuité de service** : sauvegardes testées, monitoring, alerting — plan détaillé §18, déploiement planifié sur le serveur OVH KS-5-B nouvellement provisionné
2. **Audit sécurité externe** : pen-test indépendant — démarche complémentaire de validation pour les clients Premium, planifiée avant l'ouverture commerciale du palier Premium
3. **Tests de charge** sur le serveur dédié final, validant les capacités annoncées dans le SLA

L'architecture multi-tenant *DB-per-tenant* est adaptée au segment PME/ETI ciblé et offre une isolation forte. La stratégie commerciale tri-marché (France / Belgique / Afrique francophone) est cohérente avec les capacités techniques (multi-devises, skew horloge DST-safe, mobile-first).

Document généré à partir de l'inventaire de la base de code — 64 contrôleurs API, 131 entités EF, 22 écrans mobile, ~30 modules web.

Version du 2026-05-12. Mises à jour à chaque itération significative.